
Translate Needs To Integration Requirements

Given a use case, identify integration security / authentication / authorization requirements.

Develop your career with Salesforce Training and Certification Preparation

Table of Contents

-  [Security](#)
-  [Certificates](#)
-  [Salesforce Identity](#)
-  [Single Sign-On](#)
-  [Connected Apps](#)
-  [SAML](#)
-  [OAuth 2.0](#)
-  [OAuth Flows](#)



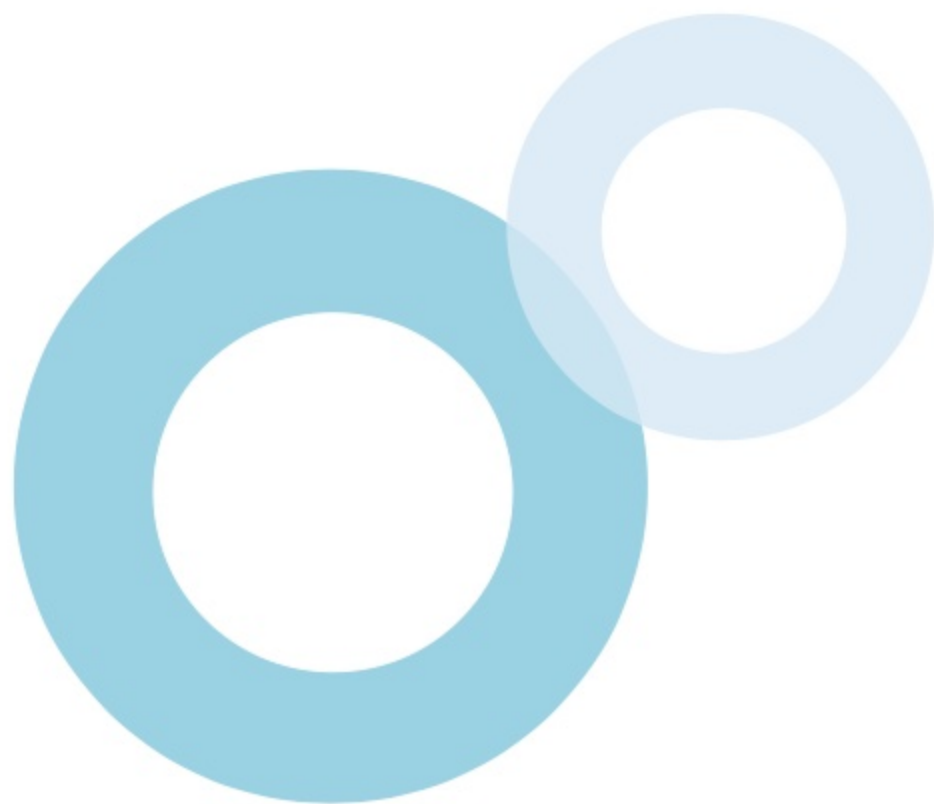
Table of Contents

-  [OpenID Connect](#)
-  [Delegated Authentication](#)
-  [Experience Cloud Site Authentication](#)
-  [Use Cases](#)



After studying this topic, you should be able to:

-  Identify security settings that can be configured to further enhance Salesforce's security measures
-  Determine the different methods by which external applications can be authenticated with Salesforce
-  Describe what SAML, OAuth, and OpenID Connect are and how they're used in integration solutions

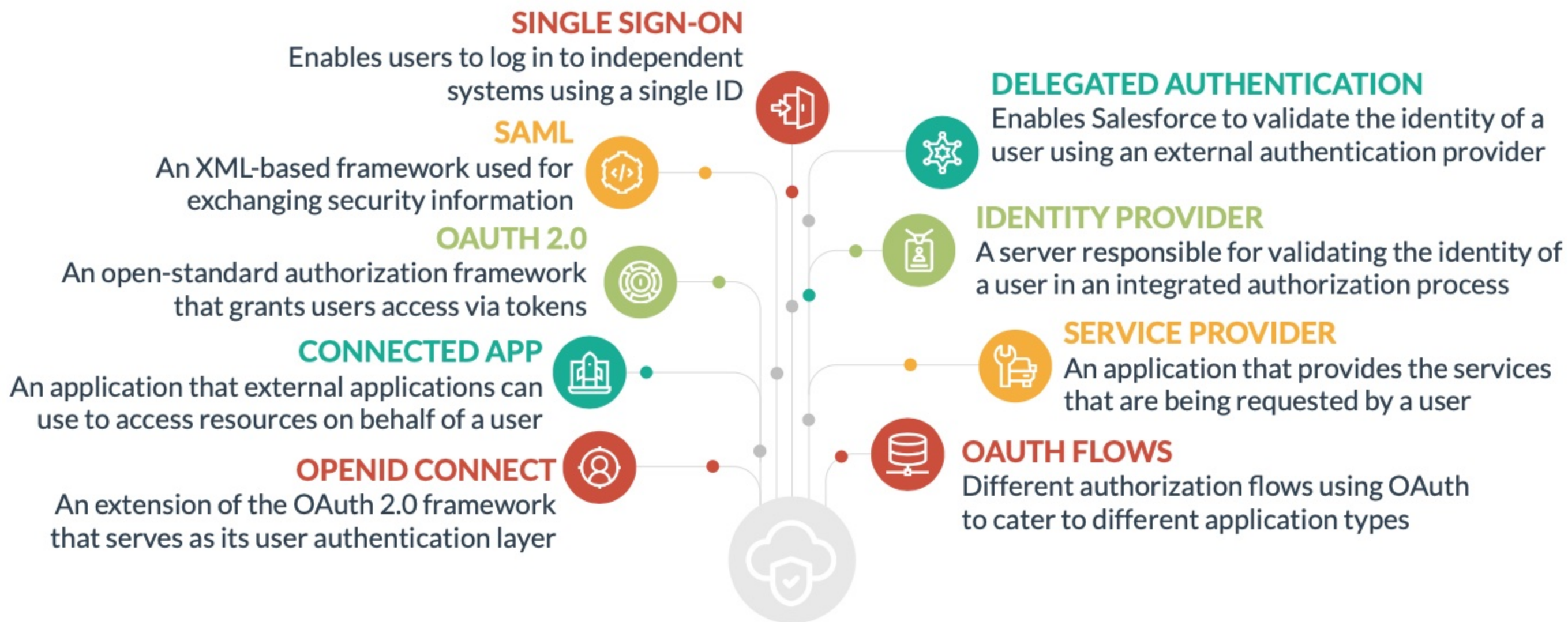


Introduction

Salesforce provides industry-standard and secure protocols for authorizing external applications with the platform. In a scenario where a user outside Salesforce needs to access the services of the platform, Salesforce can authenticate the user, or it can rely on an external service to validate the user's identity before authorizing access. Several types of authorization flows are supported to allow different types of applications such as web apps, mobile apps, servers, and IoT devices to integrate with the org. Although Salesforce uses some of the most advanced technology for protecting the multi-tenant platform, additional security procedures are always recommended to further enhance org security, which will be described in this section.



Security / Authentication / Authorization



Security

Table of Contents 

Security

Salesforce runs in a **secure environment** using a firewall and other advanced security technologies. This section describes some of the basic and recommended **security measures** or **features**.

❖ MULTI-FACTOR AUTHENTICATION

Multi-factor authentication (MFA) enhances security by requiring users to provide **additional info** when logging in, such as a **security key**.

❖ TRUSTED IP RANGE

Trusted IP ranges enable users to log in **without receiving a login challenge**, such as a verification code, if they log in **within the IP range**.

❖ SESSION RESTRICTIONS

Session security can be enhanced through session settings such as **timeout restrictions**, **IP address ranges**, and **security levels** that restrict access to certain types of resources based on the user's authentication method.



Security

Salesforce runs in a **secure environment** using a firewall and other advanced security technologies. The following describes some of the basic and recommended **security measures** or **features**.

❖ EXTERNAL URL REDIRECTS

When a user clicks on an **untrusted URL**, the redirect action can be automatically **blocked** or a **warning message** can be displayed to the user.

❖ SECURITY HEALTH CHECK

Salesforce provides the **Health Check** page in Setup to identify and fix potential vulnerabilities based on the org's security settings.

❖ AUDITING

Auditing can be used to diagnose potential or ongoing **security issues** in an org by checking **record modifications**, **login history**, **field history tracking**, and by monitoring setup changes using **Setup Audit Trail**.



Security

Salesforce runs in a **secure environment** using a firewall and other advanced security technologies. The following describes some of the basic and recommended **security measures** or **features**.

❖ SALESFORCE SHIELD

Salesforce Shield consists of three security tools bundled together, namely **Shield Platform Encryption**, **Event Monitoring**, and **Field Audit Trail**. **Shield Platform Encryption** meets encryption requirements of sensitive data in an org that is compliant with internal and external policies. **Event Monitoring** provides access to detailed user activity and tracks how users interact with data in the org. **Field Audit Trail** is used to determine the state and value of org data at any given time.



MFA Auto-Enablement and Enforcement



NOTES

-  In order to prevent unauthorized account access and protect customer data, **all users** are contractually required to use multi-factor authentication when logging in to Salesforce either **directly** or with **single sign-on**.
-  MFA is **enabled by default** for **direct logins** in new production orgs. Since MFA is contractually required, admins will receive **in-app messages** about MFA non-compliance if the MFA setting is disabled. The messages warn about non-compliance and offer guidance on re-enabling MFA.
-  While Salesforce doesn't prevent SSO users from logging in without MFA by default, orgs are **contractually required** to **implement MFA** for all users. To satisfy this requirement, an organization can **use SSO provider's MFA service**. As an alternative, Salesforce offers its free MFA service for **new** or **existing SSO configurations**.

Certificates

[Table of Contents](#) 

Certificates

When Salesforce interacts with other systems that **require verification**, certificates are used as **signatures** to prove the authenticity of the request.

❖ SSL COMMUNICATIONS

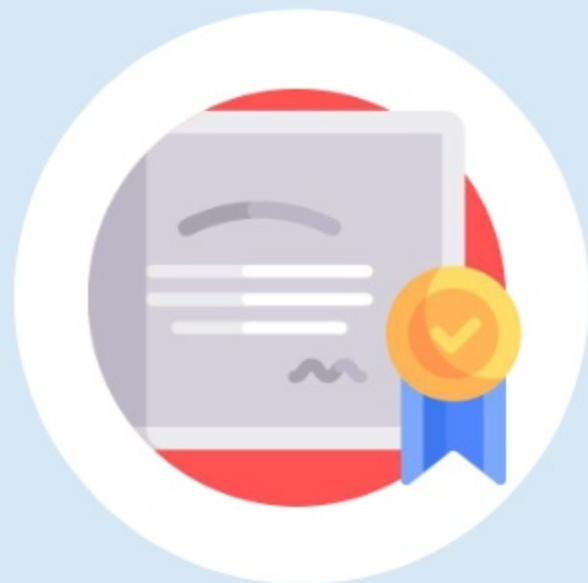
Certificates are employed in authenticated SSL communications with an external application to **verify the origin of a request**.

❖ IDENTITY PROVIDER

Certificates are utilized when an org acts as the Identity Provider to **provide the identity** of a user in an authentication flow

❖ API CLIENT CERTIFICATE

These certificates are used used by **outbound messages**, **AJAX proxy**, and delegated authentication **HTTPS callouts**



API Client Certificates

Salesforce supports the creation of **several types** of certificates. The type of certificate to use depends on the **remote endpoint** that the org needs to connect to, or what is required by the **endpoint server**.

❖ SELF-SIGNED CERTIFICATE

A certificate **signed by Salesforce** that can be used to prove that the communication coming from the org is authentic

❖ CA-SIGNED CERTIFICATE

A certificate signed by a **certificate authority (CA)**, which provides a more authoritative means of establishing the authenticity of a communication.

❖ MUTUAL AUTHENTICATION CERTIFICATE

A certificate used when **clients and servers** are required to prove their identity with each other. **SSL** or **TLS** mutual authentication can be enforced.



SSL & TLS

The **Transport Layer Security** (TLS) is an improved version of **Secure Sockets Layer** (SSL).

❖ MASTER SECRET

TLS uses a **pseudo-random function** to generate the master secret (session key used for hashing), while SSL uses a **hashed fixed-size value** of its message content.

❖ AUTHENTICATION CODE

TLS uses a hash-based message authentication code (**HMAC**) while SSL uses Message Authentication Code (**MAC**).

❖ RECOMMENDATION

TLS is **more secure** compared to SSL, which is already considered obsolete, and is the recommended protocol for **establishing secure connections** between a **server** and **client**.



One-Way and Two-Way

Two-way (or mutual) authentication is **more secure** than one-way authentication.

❖ ONE-WAY

In one-way SSL/TLS, **only the client** performs an identity validation. For example, when the client requests a resource from the server, the server hands over its public certificate. The client then verifies its authenticity with the **Certification Authority (CA)**. If authentic, the process eventually proceeds with generating the key that is used to encrypt the communication between the two parties. Subsequently, the client agrees to receive the resource it requested from the server.

❖ TWO-WAY

In two-way SSL/TLS, **both the server and client** perform validation by verifying each other's identities. After the client validates the **server's identity**, the server in turn also validates the **client's identity** using the public certificate provided by the client during the process.



Salesforce Identity

Table of Contents



Salesforce Identity

Salesforce Identity enables users to **sign in once** and have access to apps running on the **platform**, **on-premises**, **other clouds**, or **mobile devices**, and is responsible for the following **features**:

❖ SINGLE SIGN-ON (SSO)

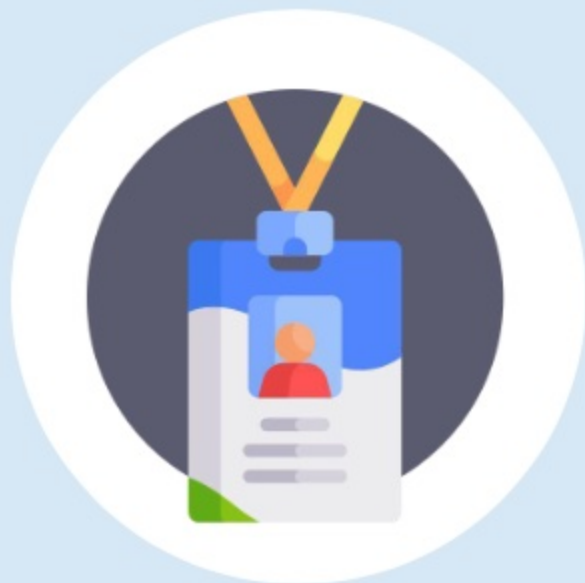
Enables users to have a **single login** and avoid the need to have **separate credentials** for logging into other apps

❖ CONNECTED APP

Enables external apps to integrate and access **Salesforce resources** using APIs and standard protocols such as **SAML**, **OAuth**, and **OpenID Connect**

❖ SOCIAL SIGN-ON

Enables users to **log in to Salesforce** using the username and password of an **external authentication provider** such as Google, Facebook, and similar services.



Salesforce Identity

Salesforce Identity enables users to **sign in once** and have access to apps running on the **platform**, **on-premises**, **other clouds**, or **mobile devices**, and is responsible for the following **features**:

❖ MULTI-FACTOR AUTHENTICATION

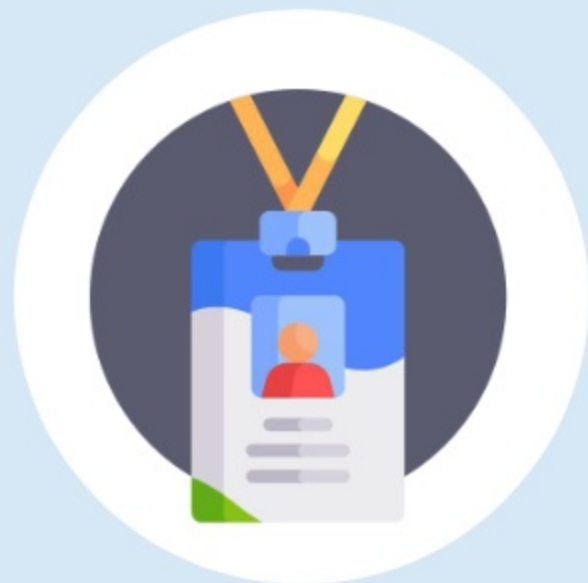
Enhances login security in the org by requiring users to perform **additional verification methods** such as a push notification to a mobile device

❖ MY DOMAIN

Provides an organization with a **custom Salesforce URL** and enables customization of the login page as well as the login process

❖ CENTRALIZED USER ACCOUNT MANAGEMENT

Enables admins to manage all their **user account tasks** in a single location and prevents end users from needing to remember **multiple credentials**



Salesforce Identity

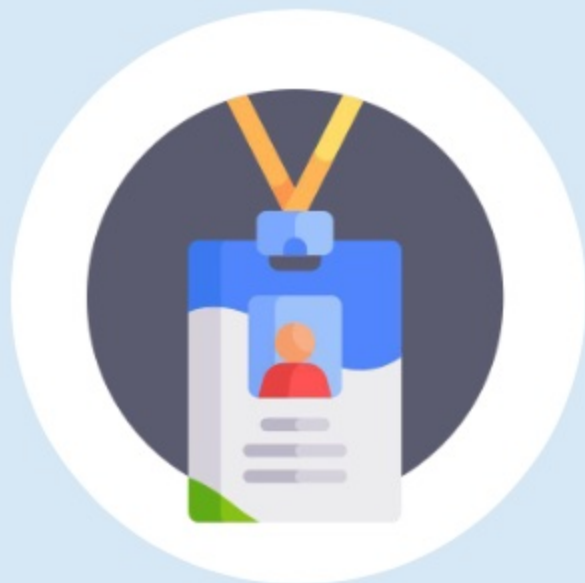
Salesforce Identity enables users to **sign in once** and have access to apps running on the **platform**, **on-premises**, **other clouds**, or **mobile devices**, and is responsible for the following **features**:

❖ USER PROVISIONING

Enables **management of user information** efficiently and securely **across multiple** systems and connected applications

❖ APP LAUNCHER

Provides a list of **standard**, **custom**, and **connected apps** in the org and enables users to access the apps without requiring them to log in again



Identity Standards and Protocols

Salesforce uses industry standards and protocols for **identity and access management**. Salesforce and integrated applications use the following **3 protocols** for authorization & authentication.

❖ SAML

Security Assertion Markup Language (SAML) is an XML-based standard for exchanging **authentication** and **authorization data** used in **single sign-on**.

❖ OAuth 2.0

The Open Authorization (OAuth) 2.0 protocol is the industry standard for authorization that **enables secure sharing of data** between systems.

❖ OpenID Connect

The OpenID Connect protocol, used in **social sign-on**, adds an **authentication layer** on top of OAuth 2.0 for the secure exchange of **user information**.



Single Sign-On

Table of Contents 

Single Sign-On (SSO)

Single Sign-On is an **authentication method** that enables a user to access **multiple independent systems** by logging in once, without having to log in separately.

❖ SALESFORCE IDENTITY

Salesforce supports SSO through Salesforce Identity, which is a feature that provides **identity** and **access management services**

❖ BENEFITS

Single sign-on avoids **password fatigue** as users only need to remember a **single username** and **password** combination that already provides access to Salesforce and any integrated applications.



Single Sign-On (SSO)

Single Sign-On is an **authentication method** that enables a user to access **multiple independent systems** by logging in once only or without having to log in separately.

❖ SECURITY

Single sign-on enhances security through **network password policies** and automatic **provisioning** and **de-provisioning** of users. Also, credentials are used once only during authorization and **minimize their exposure**.

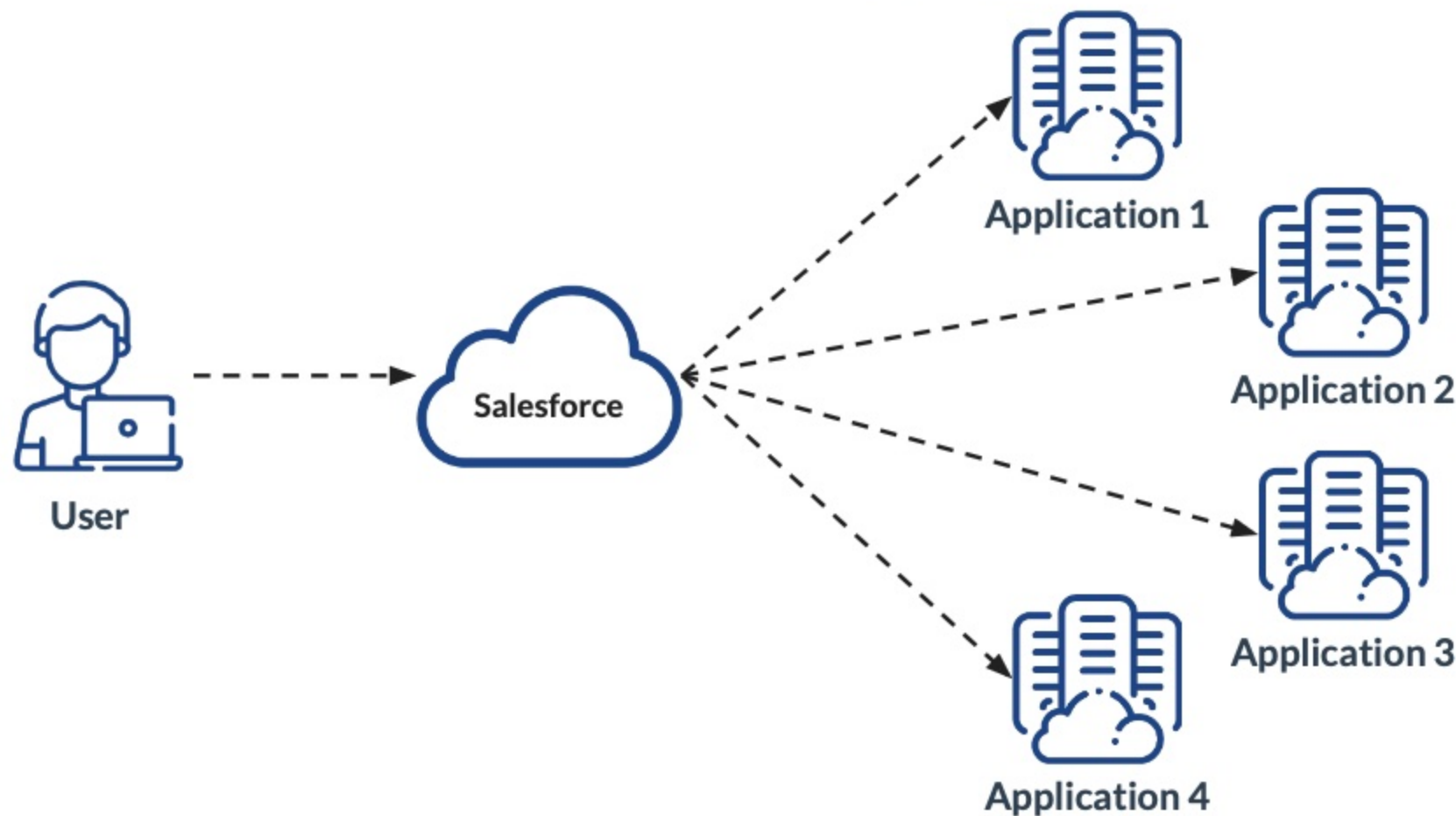
❖ IMPLEMENTATION

Users can log in to Salesforce using single sign-on by implementing one of the following standards that is supported by the platform: **Security Assertion Markup Language (SAML)** or **OpenID Connect**. SSO registration handlers can be built using **Flow Builder**, with actions to retrieve and generate user information **without requiring Apex code**.



Single Sign-On (SSO)

In the example illustration below, single sign-on enables users to **access other applications** after having logged in to Salesforce.



In other integration scenarios, Salesforce can **rely on an external application** to authenticate users before they can be logged in to the org. Alternatively, a user may access an external application, and the application then **relies on Salesforce** to authenticate the user.

Connected Apps

Table of Contents



Connected Apps

Salesforce uses connected apps to **authorize external applications** that support **SAML**, **OAuth**, and **OpenID Connect** protocols. Connected apps provide the following capabilities to Salesforce.

❖ API INTEGRATION

Connected apps access Salesforce data and consume services **on behalf of the external application**. For example, an order management system collects contact information from Salesforce through a connected app.

❖ SERVICE PROVIDER INTEGRATION

Connected apps can be used to integrate service providers when Salesforce functions as the **identity provider**. For example, a third-party app first asks Salesforce to authenticate the user before the user is allowed access. This user authentication can be performed using **SAML**, or if the app supports OpenID Connect tokens, then **OpenID Connect** can be utilized.



Connected Apps

Salesforce uses connected apps to **authorize external applications** that support **SAML**, **OAuth**, and **OpenID Connect** protocols. Connected apps provide Salesforce the following capabilities.

❖ AUTHORIZATION SERVER

Using the **OpenID Connect dynamic client registration**, Salesforce can run as an **OAuth authorization server** by authorizing and authenticating requests from connected apps, which can be **dynamically created** (as client apps) from an external system where the protected resources are hosted.

❖ ACCESS MANAGEMENT

Access to Salesforce data through the connected app can be controlled by setting **security policies** or by defining which users have access by assigning **profiles** to the connected app. A **refresh token policy** can be scheduled to automatically revoke a connected app's access to Salesforce data, in conjunction with other security controls.



SAML

[Table of Contents](#) 

SAML

SAML is an **OASIS** (Organization for Advancement of Structured Information Standards) protocol for single sign-on. In **single sign-on flows**, there are **3 roles** involved.

❖ USER

The entity **requesting access** to the service provider and requires authentication

❖ IDENTITY PROVIDER

The server that **verifies user identity** and provides an **assertion**, which is XML data that confirms the identity of the user, to the service provider

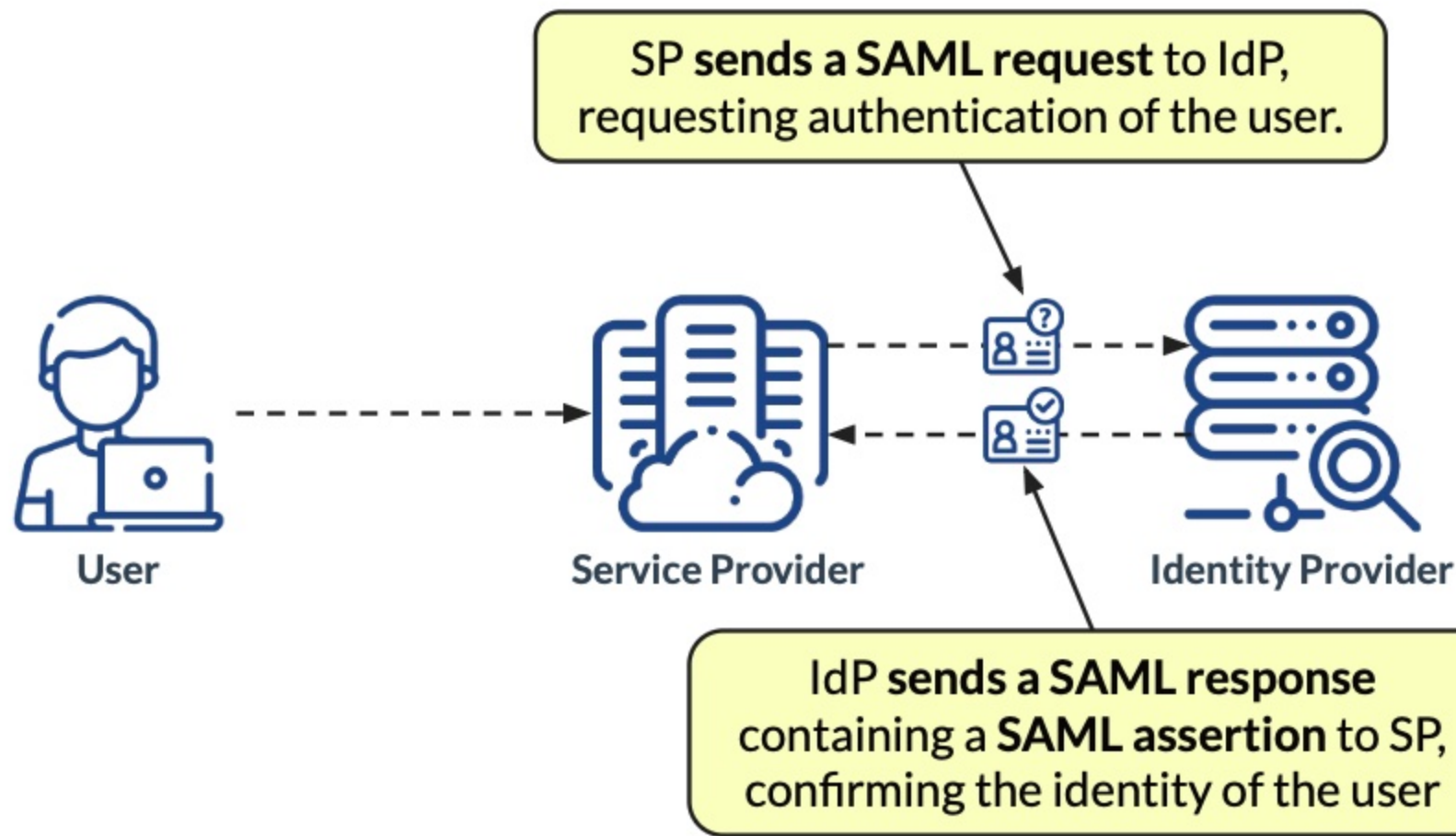
❖ SERVICE PROVIDER

The application that **consumes assertions** and **provides the service** requested by the user



Identity Provider and Service Provider

In a SAML flow, **Service Provider (SP)** relies on the **Identity Provider (IdP)** to validate and confirm the **identity** of the user requesting access to its service.



SAML Assertion

The Identity Provider responds with an assertion to the service provider as proof of the **user's identity**. A SAML assertion is an **XML document** that contains the following information.

❖ IDENTITY PROVIDER

The **name** and **digital signature** of the Identity Provider

❖ SERVICE PROVIDER

The **entity ID** or **name** of the Service Provider

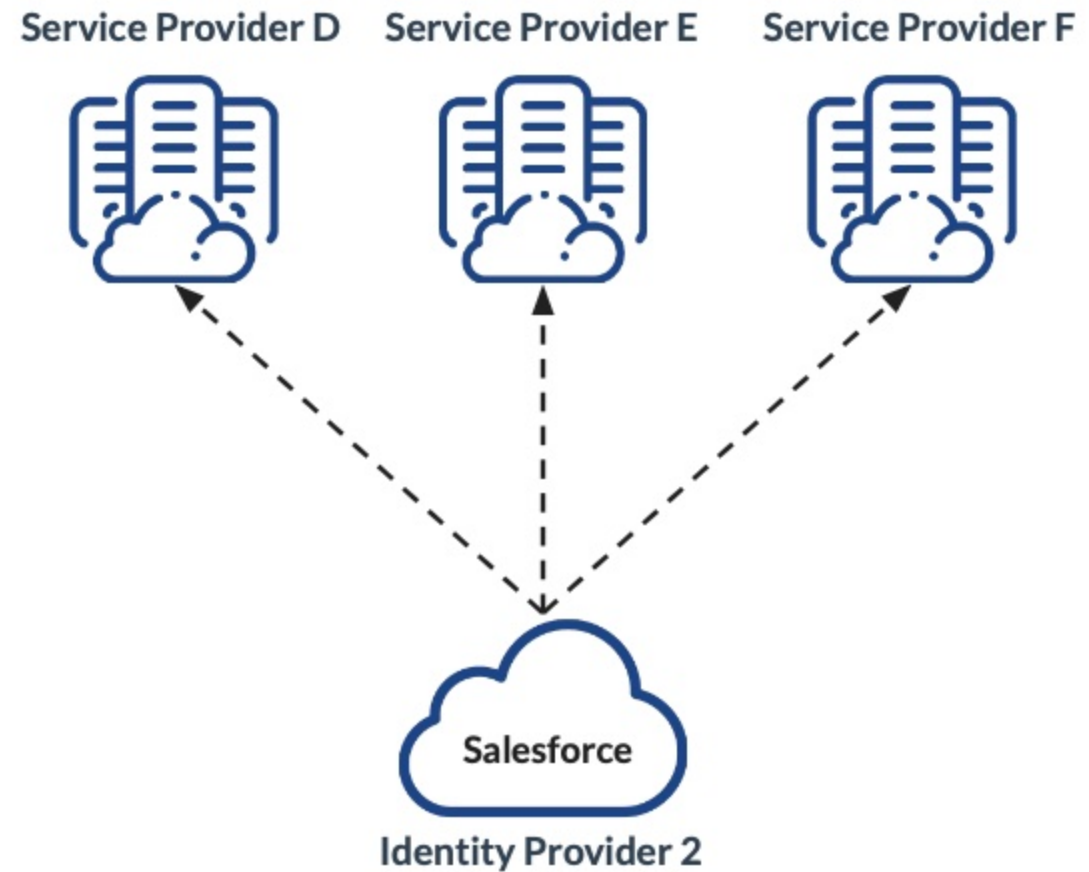
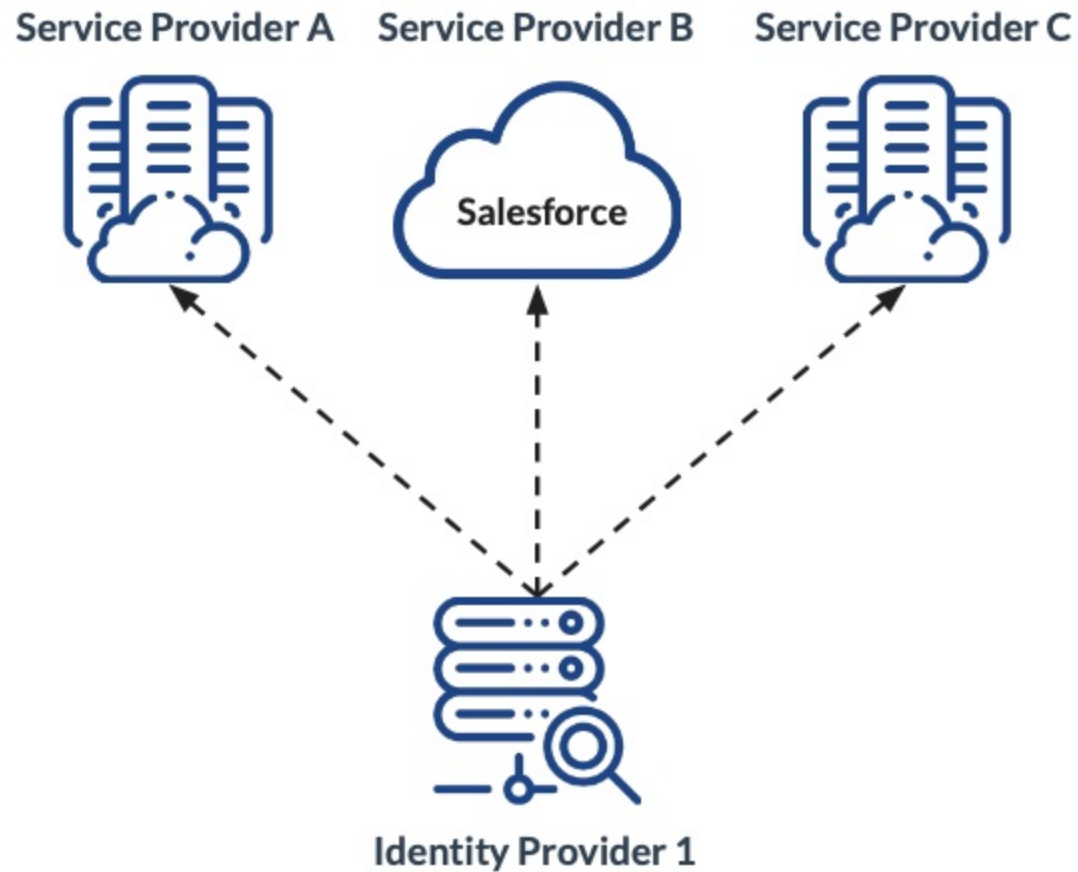
❖ SUBJECT

The **Salesforce username**, or an enterprise-wide username known as a **Federation ID**



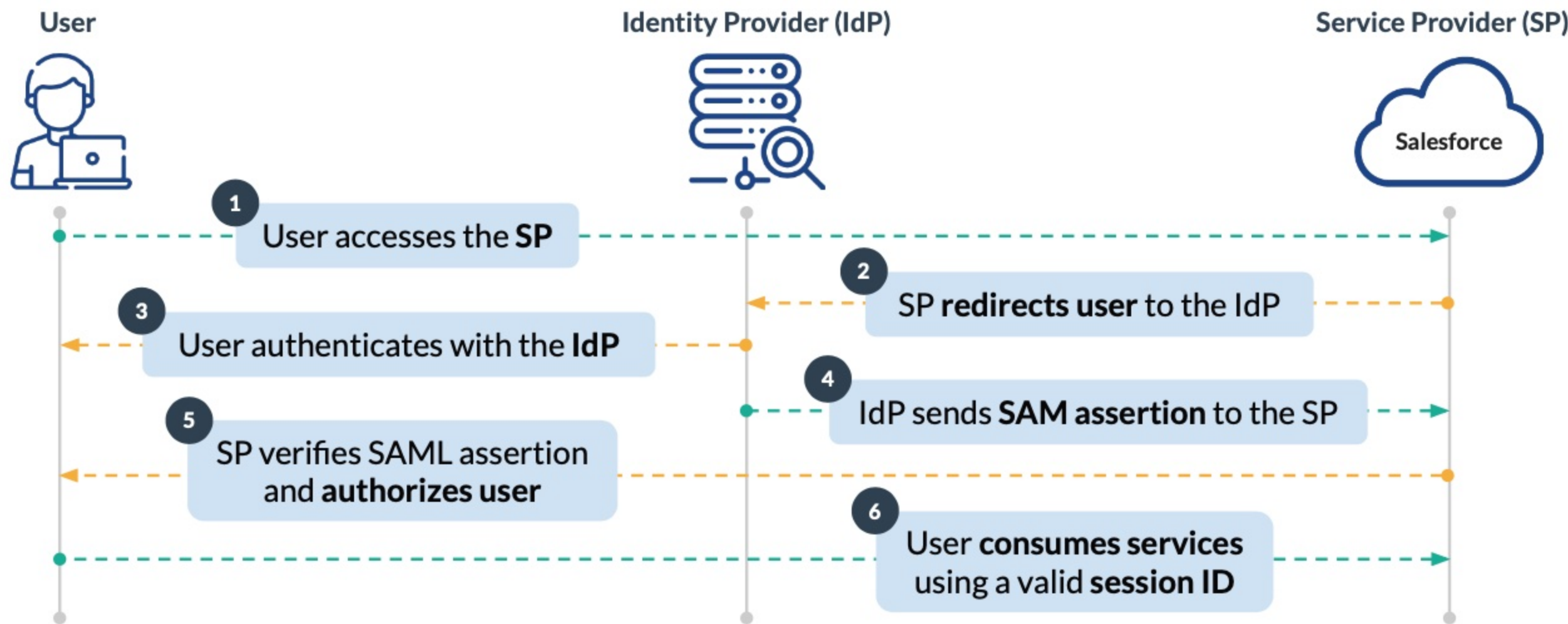
Identity Provider and Service Provider

Salesforce can act as one of the **service providers**, the **identity provider**, or **both**.



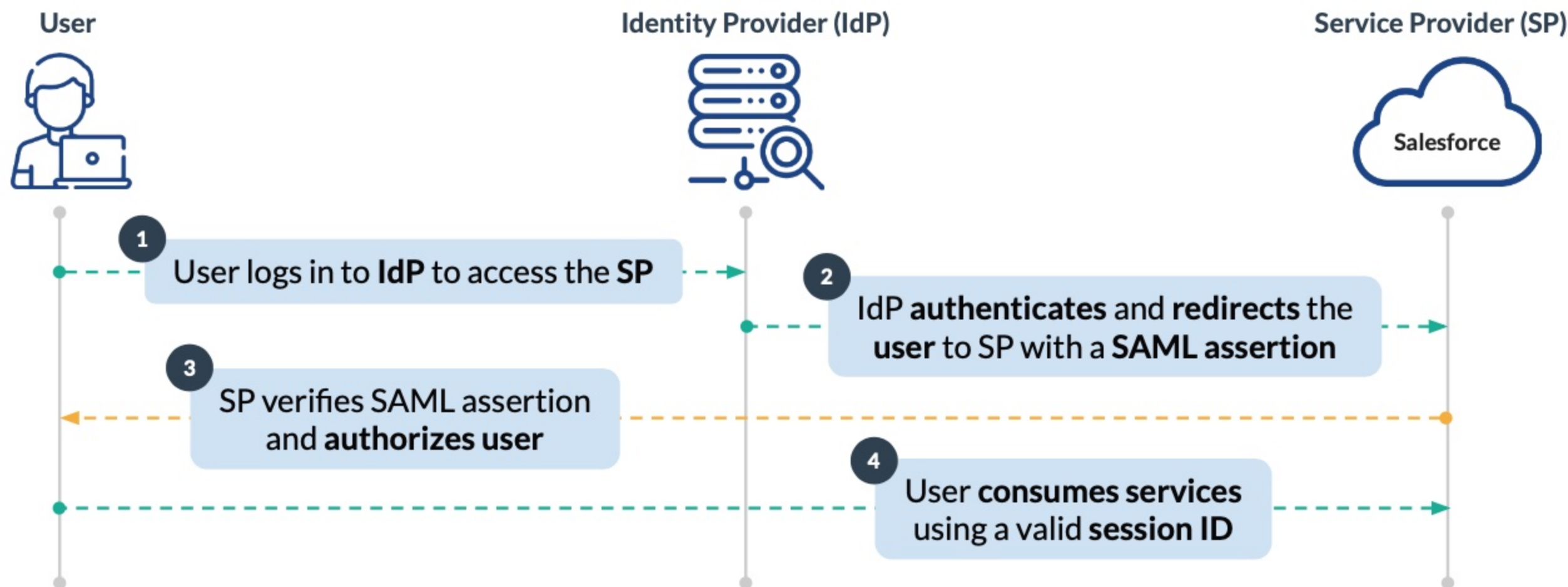
SAML Flow (SP-Initiated)

When Salesforce is the **Service Provider**, a SAML flow can be initiated by a **user** accessing the org.



SAML Flow (IdP-Initiated)

When **Salesforce** is the Service Provider, a SAML flow can also be initiated by the **Identity Provider**.



Just-in-Time Provisioning

SAML supports Just-in-Time (**JIT**) provisioning to automatically **create a new user** in Salesforce when logging in for the first time with **single sign-on**.

❖ SSO SETTINGS

In **Single Sign-On Settings** in Salesforce Setup, the **User Provisioning Enabled** can be selected in the **Just-in-time User Provisioning** section.

❖ SAML ASSERTION

The **user details** contained in the SAML assertion that is passed by the **identity provider** is used in creating the user account in Salesforce.

❖ JIT HANDLER

A **JIT handler** in Salesforce is responsible for **authenticating**, **creating**, or **updating** user accounts.



Just-in-Time Provisioning

SAML supports Just-in-Time (**JIT**) provisioning to automatically **create a new user** in Salesforce when logging in the first time with **single sign-on**.

❖ STANDARD JIT PROVISIONING

Salesforce provides standard provisioning where users are **provisioned** based on **attributes** included in the **SAML assertion**.

❖ CUSTOM JIT PROVISIONING

The JIT provisioning logic can be customized by using an **Apex handler**, which is a class that implements the **Auth.SamlJitHandler** interface.



OAuth 2.0

[Table of Contents](#) 

OAuth 2.0

Open Authorization, or OAuth, 2.0 is the industry standard **protocol for authorization** used to integrate external applications with Salesforce for **data sharing**.

❖ ACCESS TOKEN

OAuth 2.0 provides methods to acquire an **access token** for a **client application**. An access token represents the **user's permission** to access resources and so authenticates requests sent to designated API endpoints.

❖ ACCESS ON BEHALF

External applications **access protected resources** on behalf of the user. OAuth can be used in conjunction with **single sign-on**.

❖ SECURED CREDENTIALS

User passwords or credentials are not **revealed nor exposed** to the external applications.



OAuth 2.0 Roles

In an OAuth 2.0 flow, there are **4 key roles** involved.

❖ RESOURCE SERVER

Hosts the protected resources and **accepts requests** using access tokens

❖ RESOURCE OWNER

The **entity or end user** who grants access to the protected resource

❖ AUTHORIZATION SERVER

Issues access tokens to the client after authentication and authorization

❖ CLIENT

Application **requesting resource access** on behalf of the resource owner



OAuth 2.0 Tokens

In OAuth 2.0, there are **4 types** of tokens.

❖ AUTHORIZATION CODE

A temporary code that will be **exchanged for an access token**

❖ ACCESS TOKEN

A token used by client to **access protected resources** in the server

❖ REFRESH TOKEN

A long-lived token that is used to **acquire a new access token**

❖ ID TOKEN

A security token that contains **information related to the end user**



Access Tokens

An access token **authenticates a client's access** to protected resources on the resource server.

❖ PROPERTIES

An access token is a **string** and has a **short lifespan** or an **expiration**.

❖ BEARER TOKEN

An access token is used as a bearer token, meaning the entity that bears the token **can access protected resources** without requiring further identification.

❖ EXPIRY

When an access token expires, the client can either re-authenticate or use a refresh token to acquire a **new access token**.



OAuth Terms

The following describes some **other terms** used in OAuth authentication.

❖ CONSUMER KEY

The key used by a consumer (client) application, such as an external application, to **identify itself** when requesting **authorization** from a Salesforce user to act on the **user's behalf**. The consumer key is also referred to as the **client ID**.

❖ CONSUMER SECRET

A secret, or confidential data, that is used to **establish** that the client possessing the consumer secret is the **legitimate owner** of the consumer key. The consumer secret is also referred to as the **client secret**.



OAuth Endpoints

Salesforce provides endpoints that can be used to perform requests specific to **OAuth access tokens**.

❖ AUTHORIZATION ENDPOINT

This OAuth endpoint URL is used to perform authorization requests:
<https://login.salesforce.com/services/oauth2/authorize>

❖ TOKEN ENDPOINT

This OAuth endpoint URL is used to request an access token:
<https://login.salesforce.com/services/oauth2/token>

❖ REVOCATION ENDPOINT

This OAuth endpoint URL is used to revoke an access token:
<https://login.salesforce.com/services/oauth2/revoke>



OAuth Flows

[Table of Contents](#) 

OAuth Flows

Different OAuth flows are available that can be used by a **connected app** based on the **requirement** or **type of application** that needs to be integrated with Salesforce.



WEB SERVER

The flow used for integrating external web applications



USER-AGENT

The flow used for integrating desktop and mobile applications



JWT BEARER

The flow used for server-to-server integration



DEVICE

The flow used for Internet of Things (IoT) integration



SAML BEARER ASSERTION

The flow used to request an access token via SAML



SAML ASSERTION

The flow used as an alternative for services using SAML

OAuth Flows



USERNAME-PASSWORD

The flow used where external app stores the user's credentials



CLIENT-CREDENTIALS

The flow that uses a consumer key and consumer secret



REFRESH TOKEN

The flow used to request a new access token

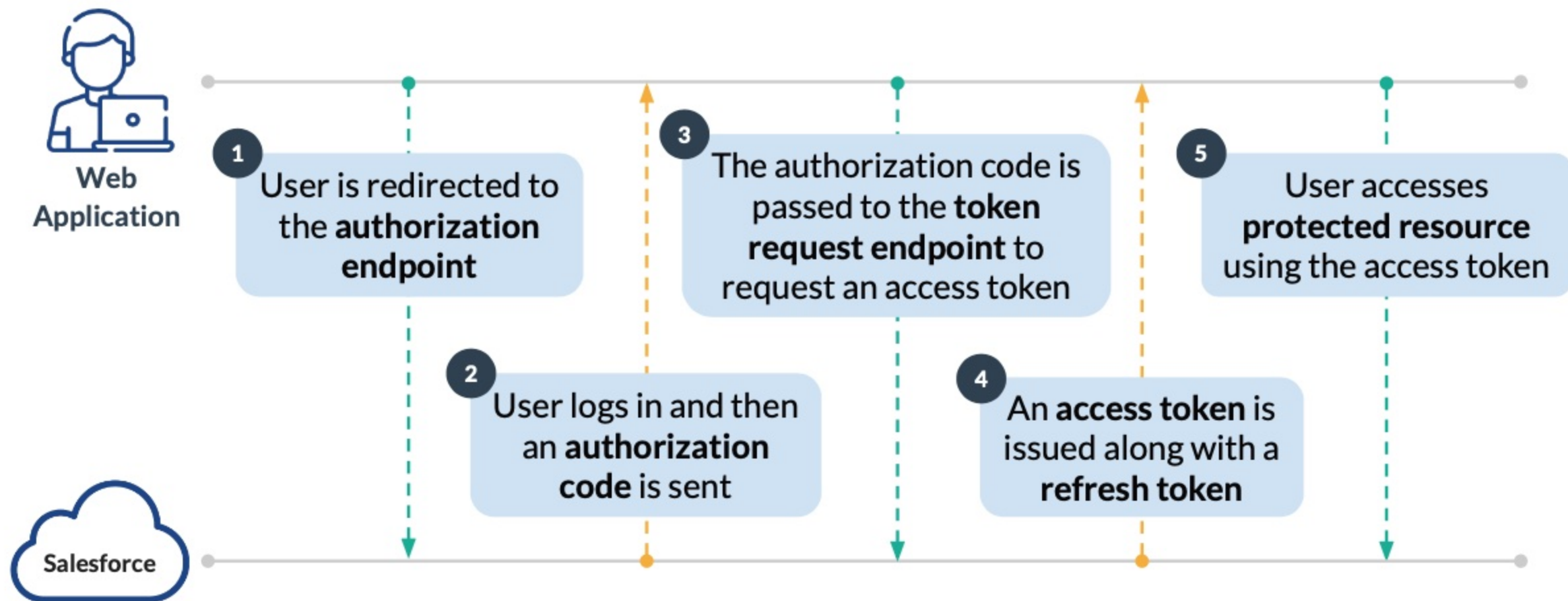


TOKEN EXCHANGE

The flow that exchanges external tokens for Salesforce tokens

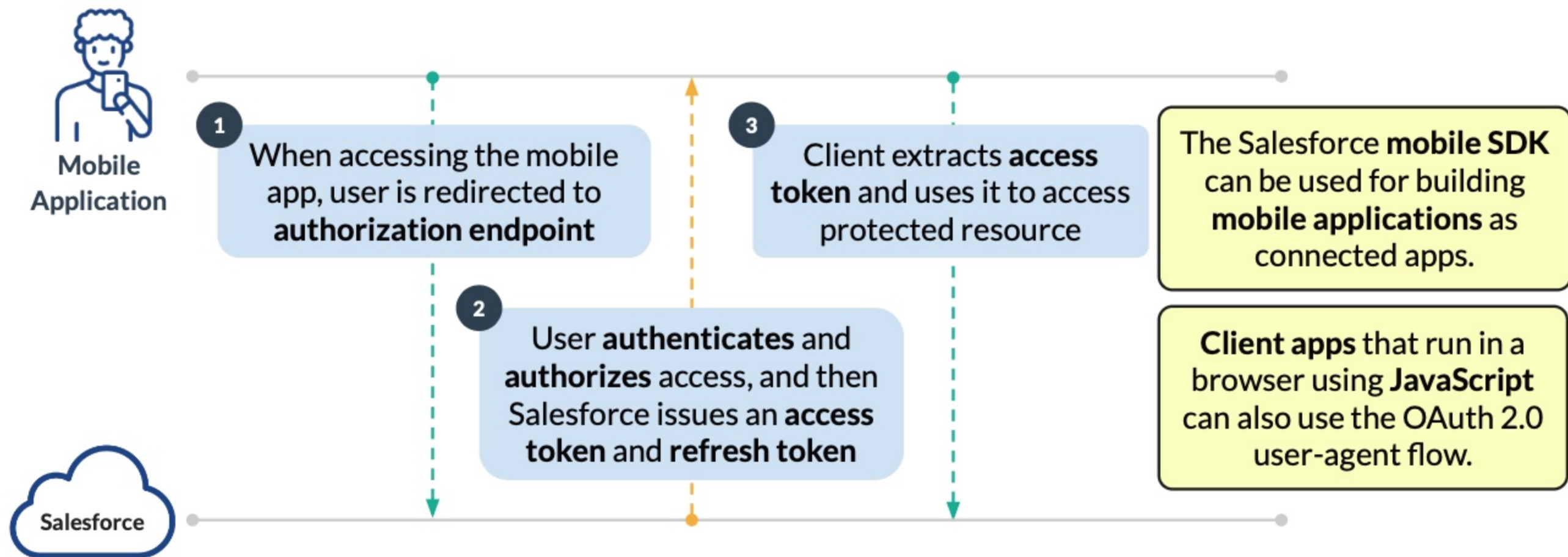
Web Server Flow

The OAuth 2.0 web server flow is used to **integrate web apps** hosted on an external server. The web app uses the **client ID** and **client secret** of the connected app in the authentication process.



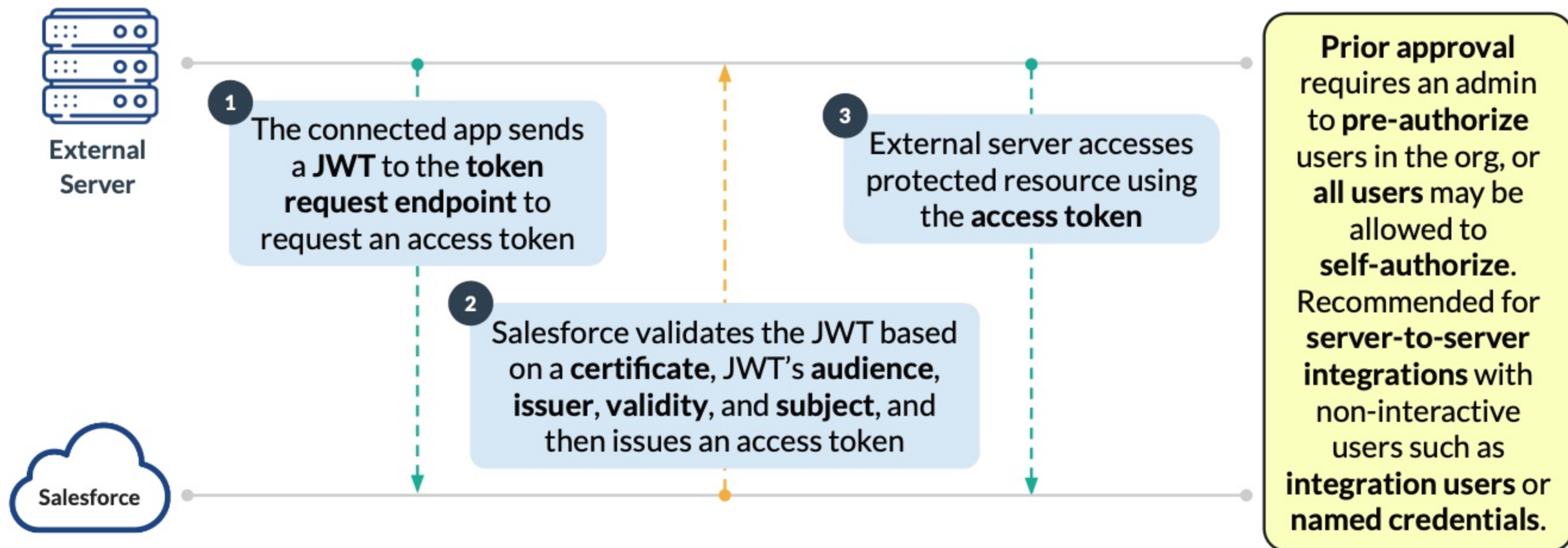
User-Agent Flow

The OAuth 2.0 user-agent flow is used to **integrate applications** that reside on a user's device, such as a **mobile device**. A sample flow is illustrated below:



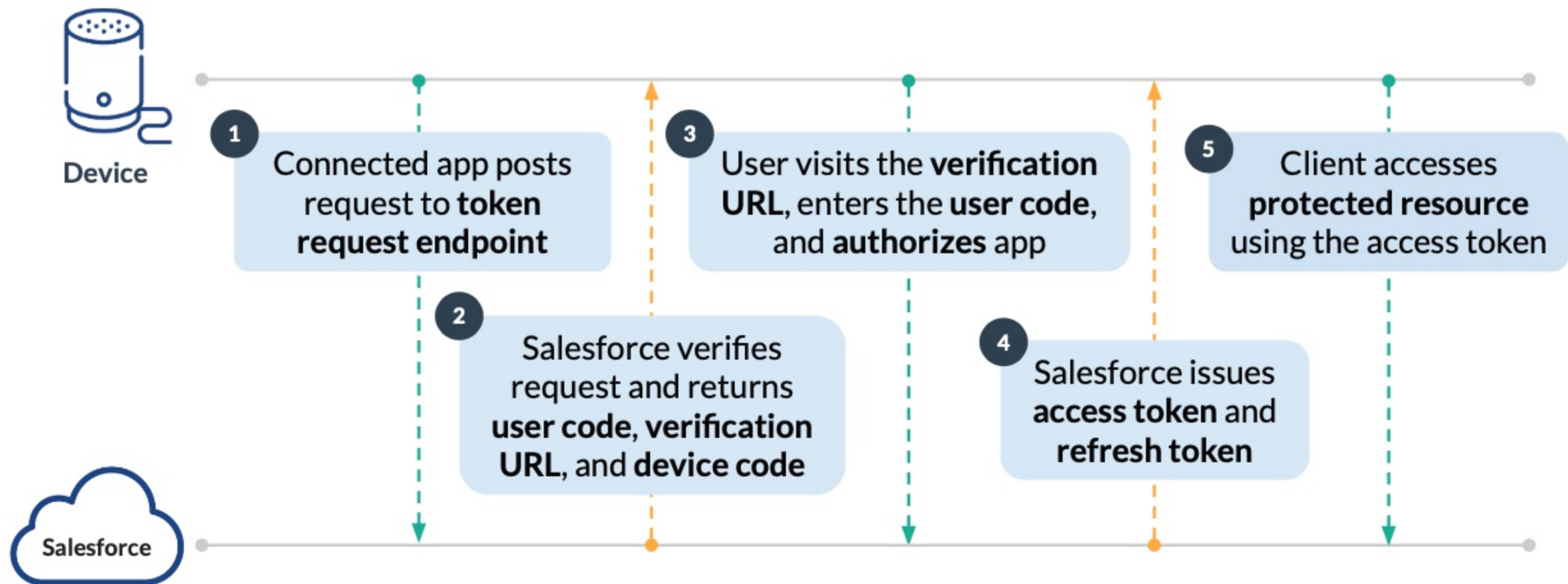
JWT Bearer Flow

The OAuth 2.0 JSON Web Token (JWT) uses JWT to **integrate servers** and authorize access without requiring a login in each time. **Prior approval** of the client app is required in this flow.



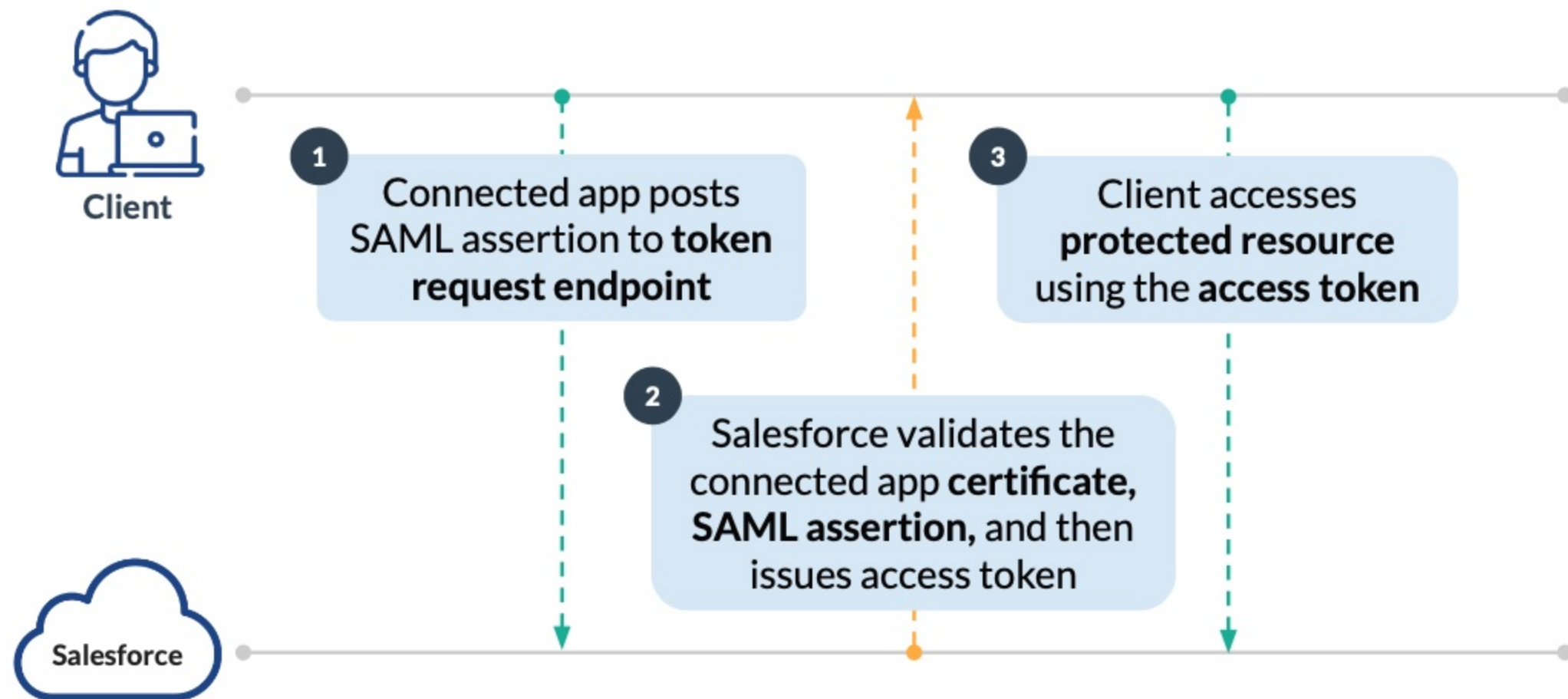
Device Flow

The OAuth 2.0 device flow is used to **integrate IoT devices**, which are devices that can send or receive data over the internet. **Command-line apps** can also use this OAuth flow.



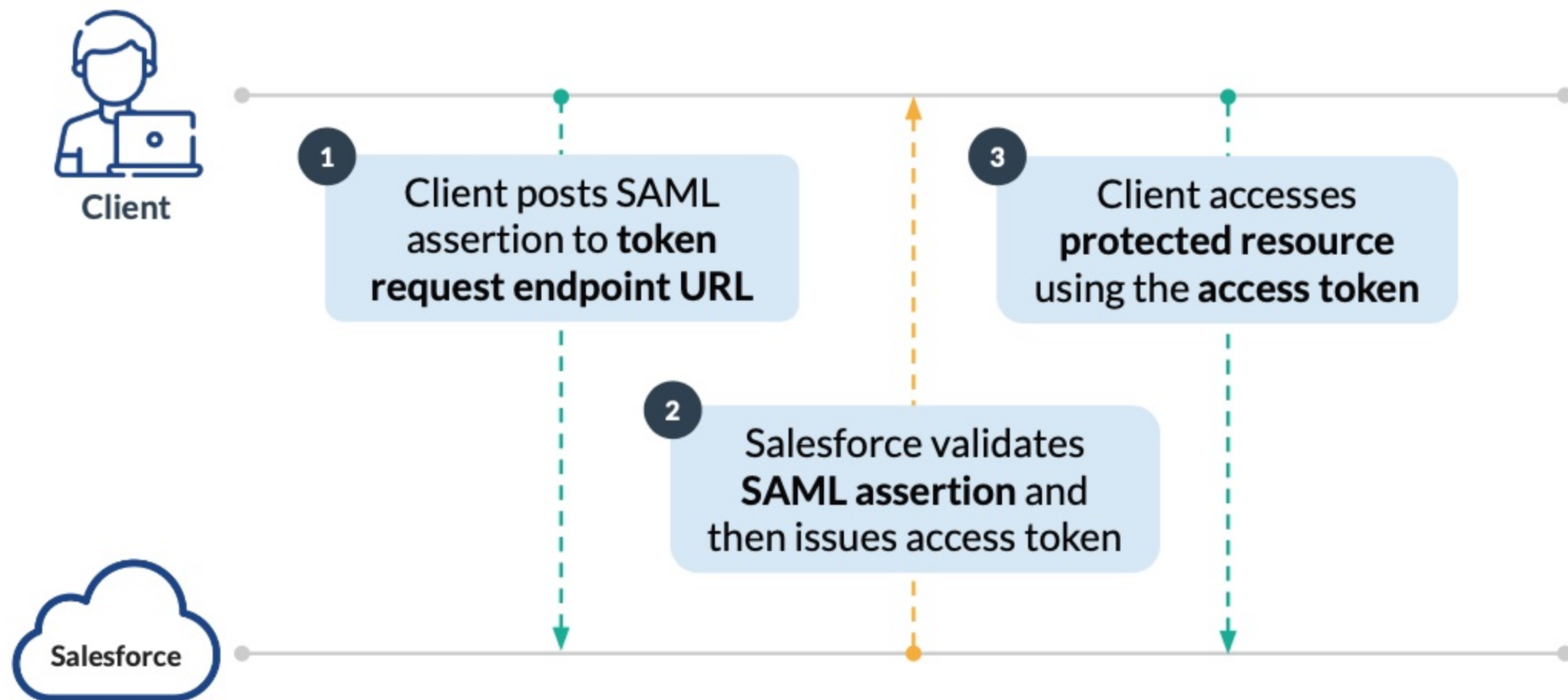
SAML Bearer Assertion Flow

The OAuth 2.0 SAML Bearer Assertion flow can be used to authorize client applications by using a **SAML assertion** from a previous authorization to request an **OAuth access token**.



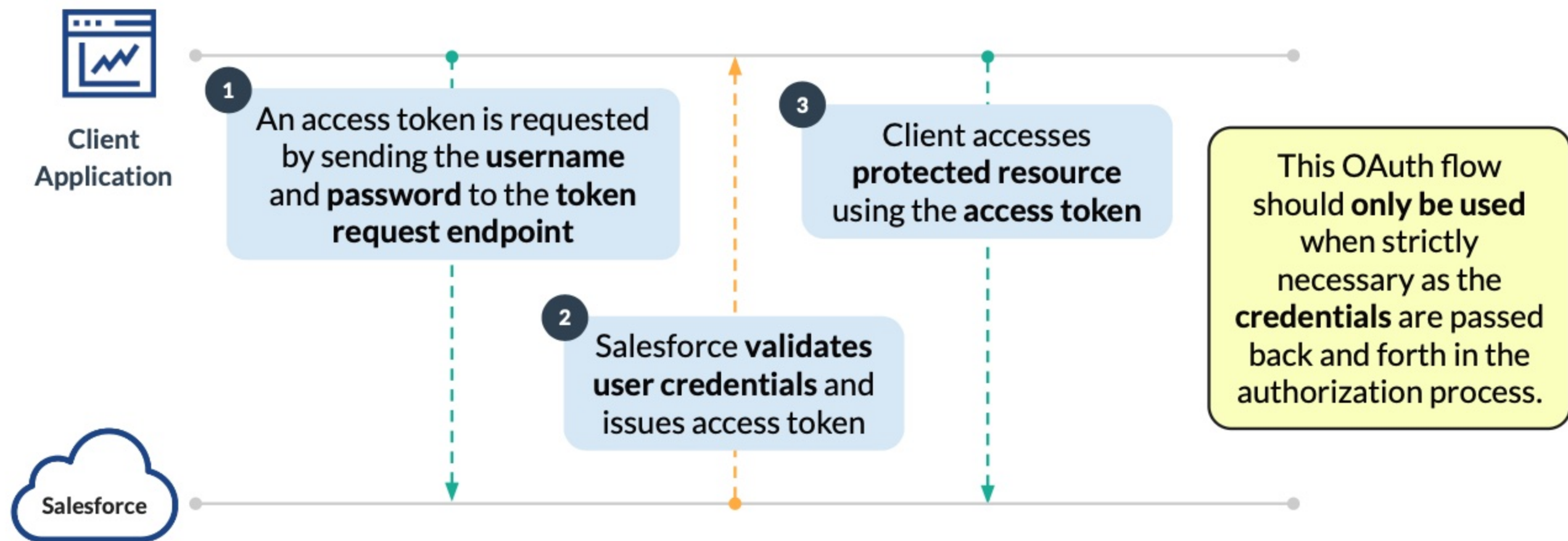
SAML Assertion Flow

The OAuth 2.0 SAML Assertion flow can be used as an **alternative** for orgs that use **SAML to access Salesforce**. In this flow type, a connected app is **not required**.



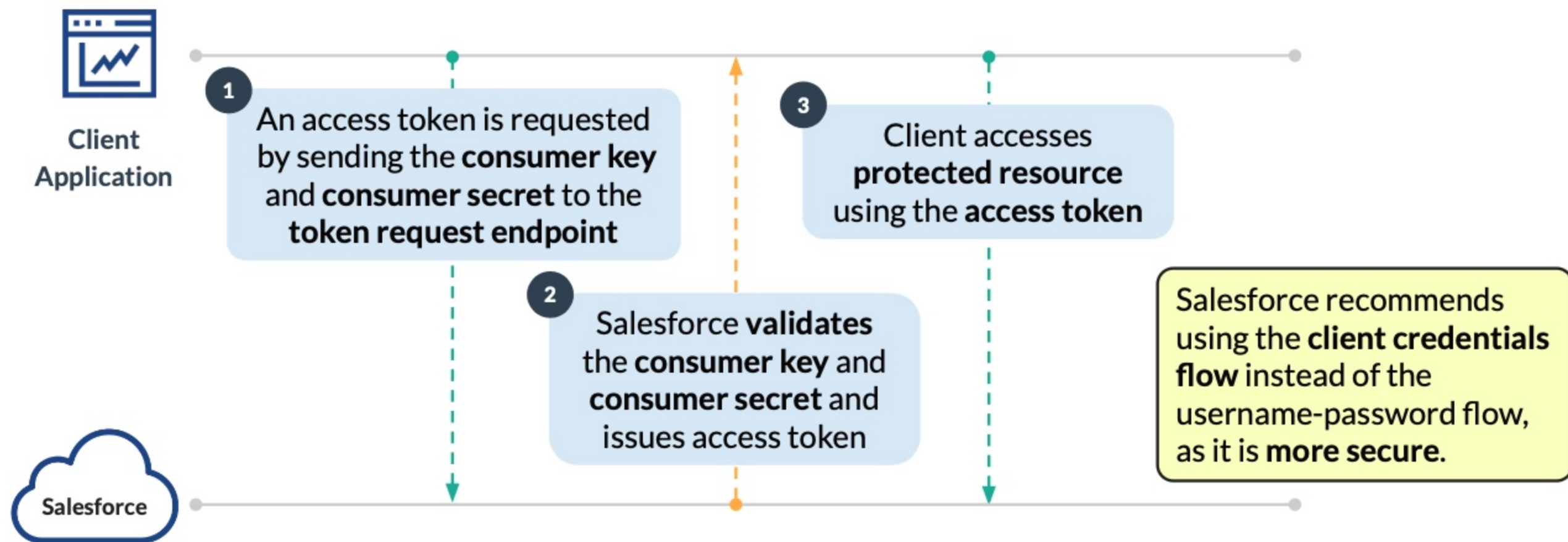
Username-Password Flow

The OAuth 2.0 username-password flow can be used to authorize clients through a connected app. In this flow, the app stores the **user credentials**. Also, **no refresh token** is issued.



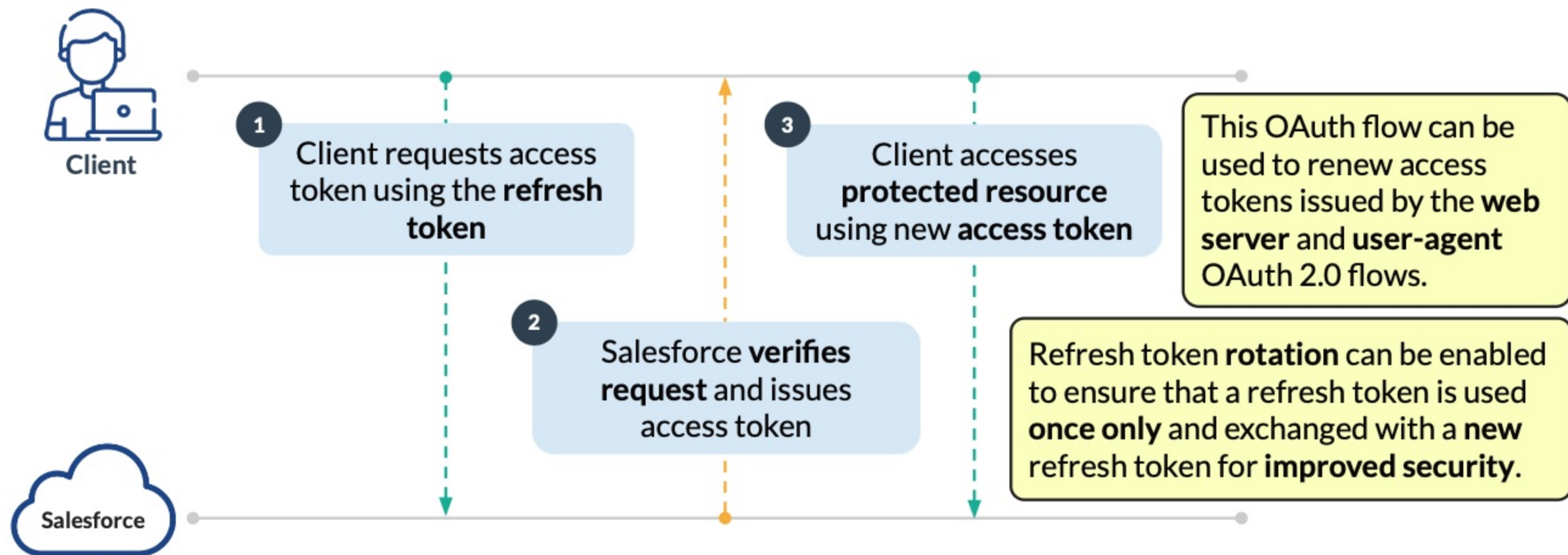
Client Credentials Flow

The OAuth 2.0 client credentials flow authorizes clients through a connected app. In this flow, the third-party app provides the **consumer key** and **consumer secret** defined in the connected app.



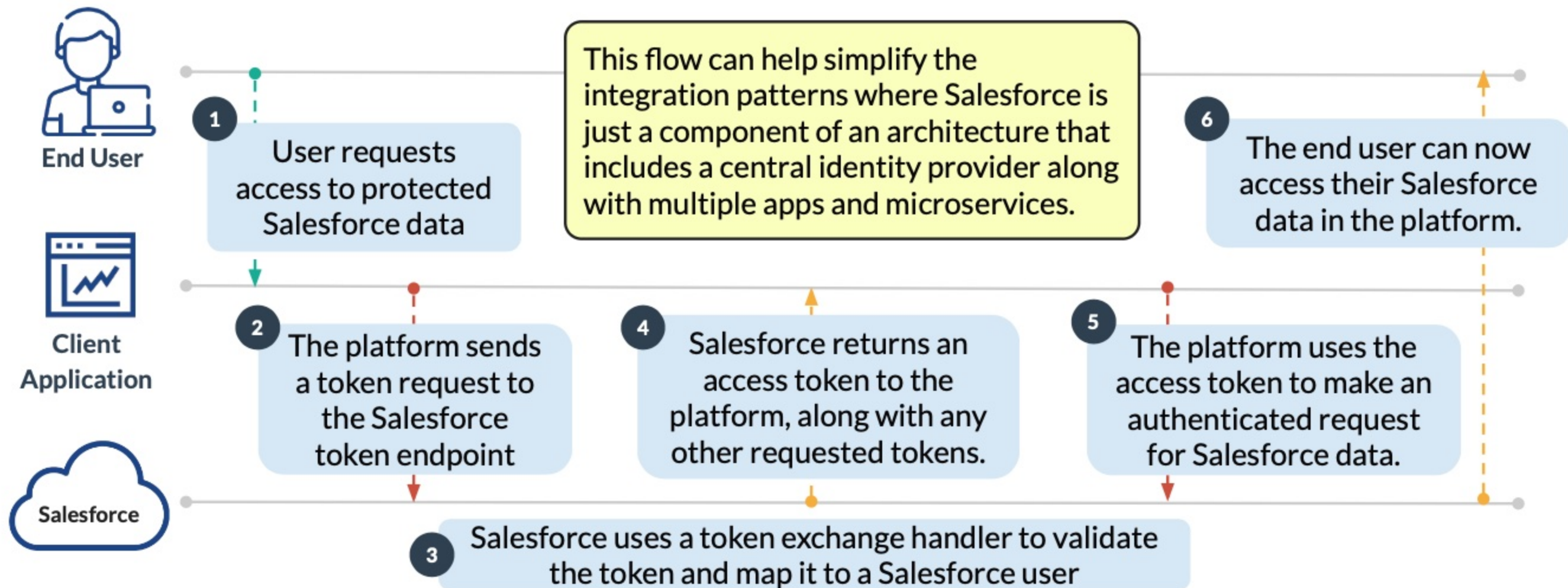
Refresh Token Flow

The OAuth 2.0 Refresh Token flow is used to acquire a **new access token** if an access token, for example, has expired by submitting a **refresh token** to the token request endpoint.



Token Exchange Flow

The OAuth 2.0 Token Exchange flow is used to exchange tokens from **external identity providers** for Salesforce tokens and grant access to Salesforce data.



OAuth Flows Summary

The following table displays a summary of some of the **properties** of certain **OAuth 2.0 authorization flows**.

	Web Server	User-Agent	JWT Bearer	UN/PW	Refresh Token
Token request method?	POST	GET	POST	POST	POST
Grant type used?	<i>authorization_code</i>	(implicit)	<i>jwt-bearer</i>	<i>password</i>	<i>refresh_token</i>
Uses client secret?					
Returns refresh token?					
Requires user to authorize?					

OpenID Connect

[Table of Contents](#)



OpenID Connect

The OpenID Connect protocol serves as an extension of OAuth 2.0 that adds an **authentication layer** and enables secure exchange of **user information**.

❖ USER IDENTIFICATION

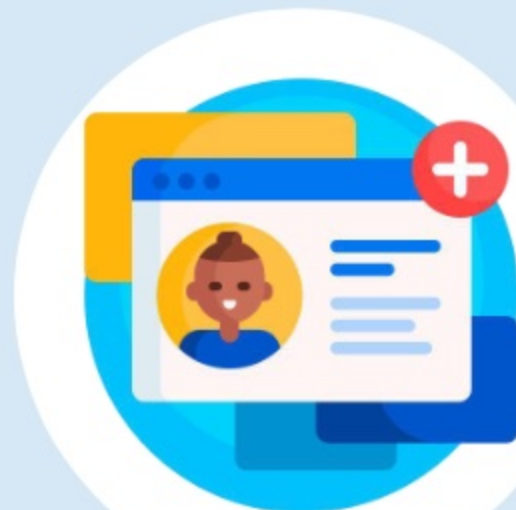
OpenID Connect is used to **identify details** of the user associated with an **access token**.

❖ ID TOKEN

An **ID token** can be included in the response when an access token has been issued to the requesting party.

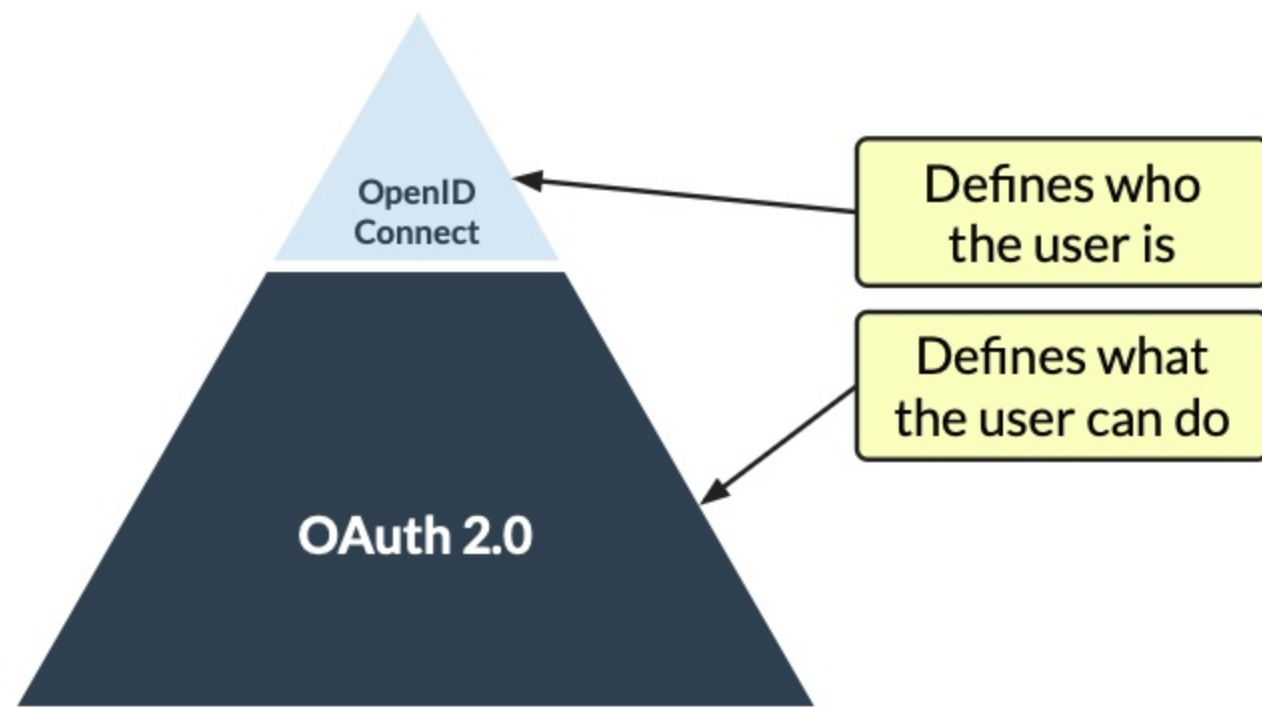
❖ QUERY INFORMATION

User details can be retrieved by sending a request to the **UserInfo** endpoint: <https://login.salesforce.com/services/oauth2/userinfo>



OpenID Connect

OAuth 2.0 was originally designed for **authorization only**. OpenID Connect, being an extension of OAuth 2.0, completes the full **authorization and authentication** capabilities of OAuth.



Authentication and Authorization

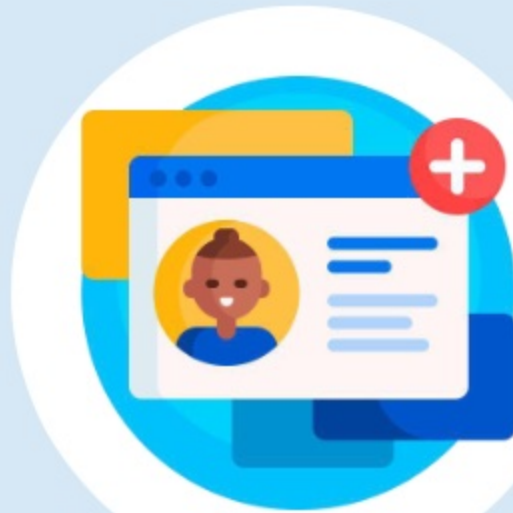
The terms **authentication** and **authorization** in some cases are **interchangeable** depending on the **context** but may cause confusion. When used strictly, the terms have **two distinct meanings**.

❖ AUTHENTICATION

Authentication refers to the process used to **verify that the user is actually who they say they are** (i.e., verifying the user's asserted identity). A very common example involves providing a username and password. Other examples include token-based authentication such as a verification code or OTP, or authentication based on biometric data such as a thumbprint, face, or voice.

❖ AUTHORIZATION

Authorization refers to the process of **providing or determining** the permissions or actions that an **authenticated user** can do, as well as the resources that can be accessed in the secured environment. So, authentication is **always performed before** authorization.



OpenID Connect

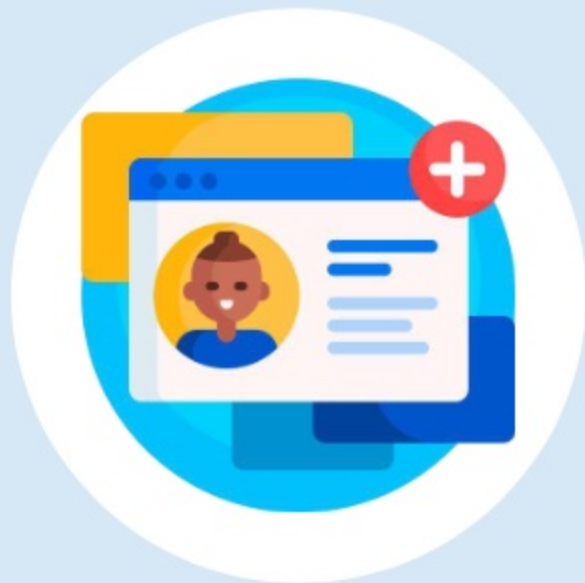
OpenID Connect can be used in **single sign-on** by redirecting a user to an Identity Provider, or **authentication provider**, to authenticate the user.

❖ AUTHENTICATION PROVIDER

A third-party **OpenID provider** can be appointed as an authentication provider. Common OpenID providers, for example, are **Amazon**, **Google**, and **PayPal**.

❖ PROVIDER REGISTRATION

To define an authentication provider, the app must be defined in the **OpenID provider's website** where the app domain is set to Salesforce. In Salesforce, an **OpenID Connect authentication provider** can be created using the **consumer key**, **consumer secret**, **authorization endpoint URL**, and **other details** provided by the application registered on the OpenID provider's website.



Delegated Authentication

[Table of Contents](#)



Delegated Authentication

Delegated authentication enables users to log in to Salesforce using **credentials** that are verified by an **external authentication provider**.

❖ SAML

SAML can be **used in conjunction** with delegated authentication.

❖ ACTIVATION

To enable delegated authentication, the “**Disable login with Salesforce credentials**” option in **Single Sign-On Settings** in Setup is selected.

❖ USER PROFILE

A user can be required to log in to Salesforce using **delegated authentication** by enabling the option in their **profile**.



Delegated Authentication

Delegated authentication allows users to log in to Salesforce using **credentials** that are verified by an **external authentication provider**.

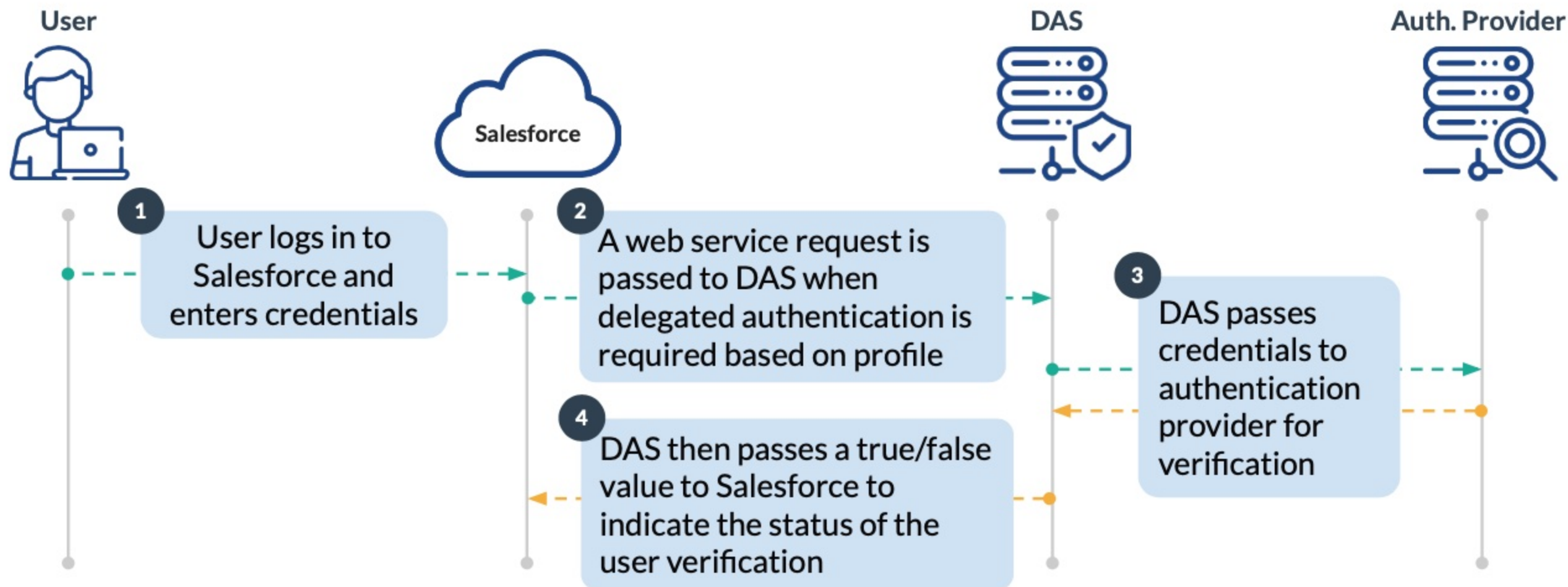
❖ LOGIN CREDENTIALS

Like single sign-on, delegated authentication enables users to use a single ID to **access multiple apps**. The difference in this authentication process is that users are required to **log in** to each application separately.



Delegated Authentication Flow

A **Delegated Authentication Service (DAS)** is used to pass user credentials to an **external authentication provider** for authentication.



Experience Cloud Site Authentication

[Table of Contents](#)



Authenticating Experience Cloud Site Users

Several options are available for **authenticating customers and employees** in an Experience Cloud site. Site users **log in** with their assigned **username and password** by default.

❖ AUTHENTICATION OPTIONS

Beyond the default settings, **SAML**, **third-party authentication providers**, or **OAuth** can be configured to authenticate and authorize users who access an Experience Cloud site.

❖ LOGIN DISCOVERY

To make it easier for users to authenticate, it is also possible to configure **self-registration** to use **Login Discovery**.

❖ SAML

If a Salesforce org already uses **SAML single sign-on (SSO)** for user authentication, this capability can be extended to Experience Cloud sites.



Authenticating Experience Cloud Site Users

Several options are available for **authenticating customers and employees** in an Experience Cloud site. Site users **log in** with their assigned **username and password** by default.

❖ AUTHENTICATION PROVIDER

An authentication provider enables users to log in to Salesforce or an Experience Cloud site with **single sign-on (SSO)** using **credentials from a third-party provider**, such as Apple, Facebook, Google, and similar services.

❖ OAUTH

OAuth is an open protocol that can be used to authorize a client application's access to an org's protected resources via an **OAuth authorization flow**.



Headless Identity APIs

Headless Identity APIs can be used to **authenticate users** while maintaining **brand consistency**.

❖ AUTHENTICATION

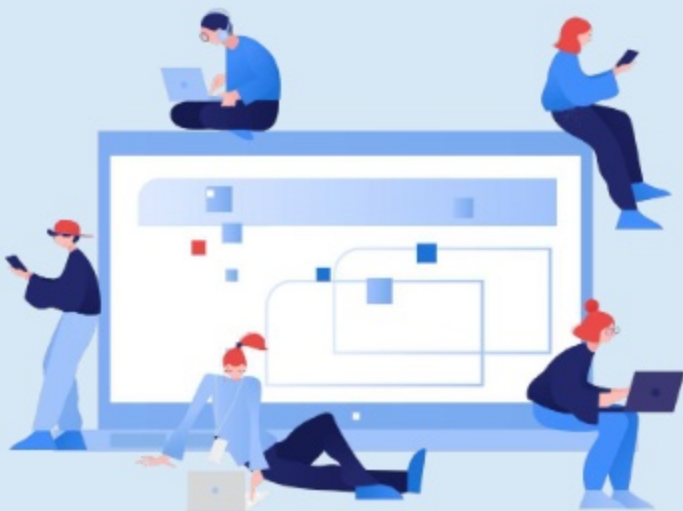
Third-party applications can use Salesforce for authentication by using the Headless Identity APIs for **Login and Forgot Password**. Identity Experience in a third-party application can be tailored using **Customer Identity** for Authentication.

❖ CONVENIENCE

Users can log in and manage passwords **without leaving the application**. Data can also be accessed.

❖ USING FLOWS

The **Authorization Code and Credentials Flow** can be used to set up headless login. Alternatively, the **Headless Passwordless Login Flow** can be used to log in to off-platform applications. The **Headless Forgot Password Flow** can be used to set up password resets.



Headless Identity APIs

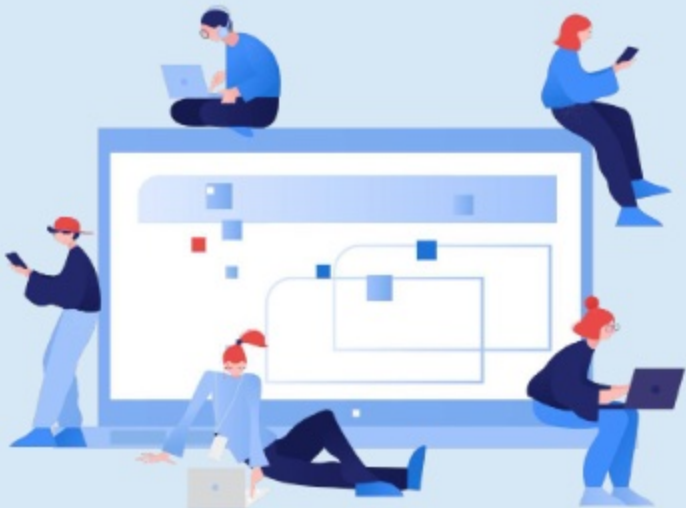
Headless Identity APIs offer even more features through **Flows**.

❖ GUEST USER FLOWS

With the **headless flow for guest users**, applications can be built to issue a **unique visitor (UVID)** for unknown users, trace their journeys to fully registered users, and collect valuable insights on the experiences that users prefer. If the user logs in or registers, the UVID can be passed into a **named user authorization flow**.

❖ MORE ADVANTAGES WITH FLOWS

ReCAPTCHA Enterprise for all Headless Identity flows helps improve security. Generating an **Apex class template for a headless registration handler** simplifies the setup process. An **email template for headless registration** helps fine-tune company branding.



Use Cases

Table of Contents 

Scenario



SCENARIO

Data in the Salesforce org of a company has been growing to the point that users are starting to notice its impact on the performance of their org. The company realizes that there is data that can be archived on one of their cloud storage facilities using a web application. Doing so will help free up storage space and help improve their org performance. The archive process should be run on a scheduled and regular basis and will be initiated from the web application.



Solution



SOLUTION

A server-to-Salesforce integration can be used in this scenario as the web application should be allowed to start the process without requiring manual user authentication in Salesforce each time. The authentication can be achieved by using the **OAuth 2.0 JWT Bearer Flow**. In this flow, the web application communicates through a connected app to request an access token by sending a **JSON Web Token**. Once Salesforce has confirmed that JWT is valid and the connected app has prior approval, Salesforce issues an access token. The web application can proceed with the necessary retrieval and delete operations in Salesforce.



Scenario



SCENARIO

A company in the manufacturing industry that uses Salesforce has recently partnered with a sales company. The sales team in the sales company needs to access customer data that is stored in Salesforce, but does not want to switch applications to view the records. The two companies have decided that the sales team should be able to access Salesforce data using the custom CRM platform that the sales company uses.



Solution



SOLUTION

In this scenario, a **connected app** can be created in Salesforce to allow access to records on behalf of the user. The **OAuth 2.0 Web Server flow** can be used, which is recommended for authorizing web applications that are hosted on an external server. For example, when a user clicks on a button on their CRM to access customer data in Salesforce the first time, the user will be asked to log in for authorization. Once the user authorizes the CRM to access Salesforce, an access token is issued which can be used by the CRM for subsequent tasks such as searching and retrieving records from the Salesforce platform.

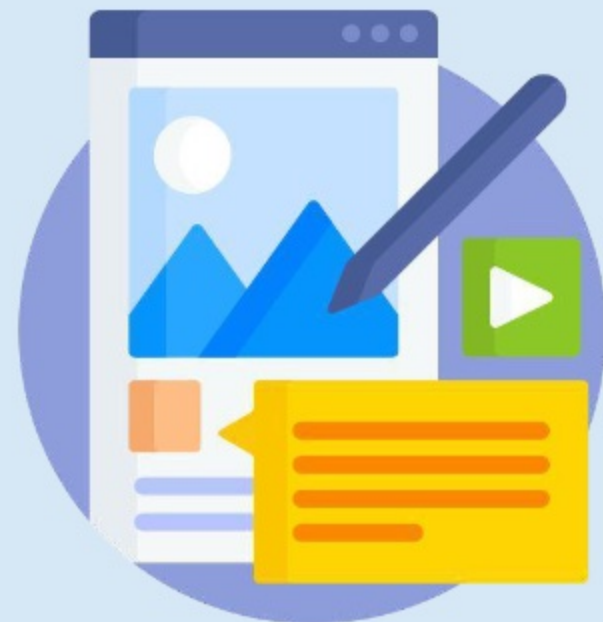


Scenario



SCENARIO

Salesforce users in a company need to use a third-party application where they can browse and use non-copyrighted images for their email campaigns. The CTO has found a web service that can meet the requirement and wants Salesforce users to access the tool directly from Salesforce and avoid logging in each time they need the tool's services. For the authorization method, the web service requires the use of the Security Assertion Markup Language (SAML) standard.

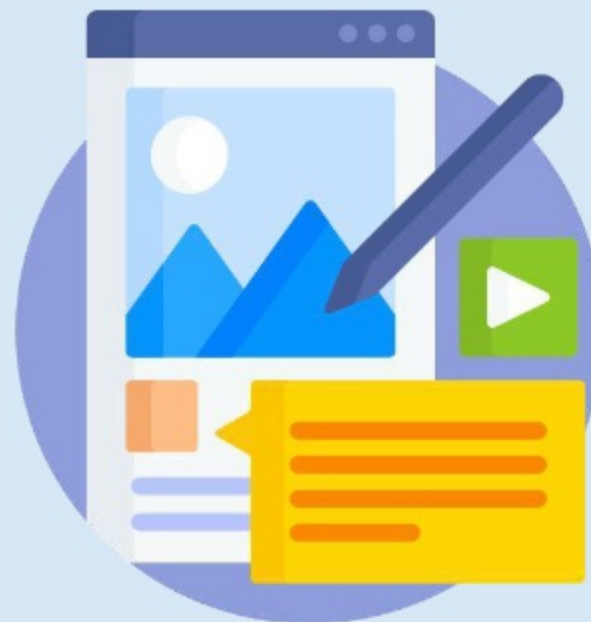


Solution



SOLUTION

Salesforce supports SAML, which is one of the protocols that can be used for single sign-on requirements. In a single sign-on scenario, the integration involves a **service provider** and a **identity provider**. In this case, the identity provider is Salesforce, and the service provider is the image web service. In an SSO flow that is initiated by the identity provider, a SAML request is not necessary and a SAML response is sent automatically to the service provider. The SAML response will contain a SAML assertion that authenticates the user. Once the service provider validates the SAML assertion, the user is automatically granted access to the image web service.

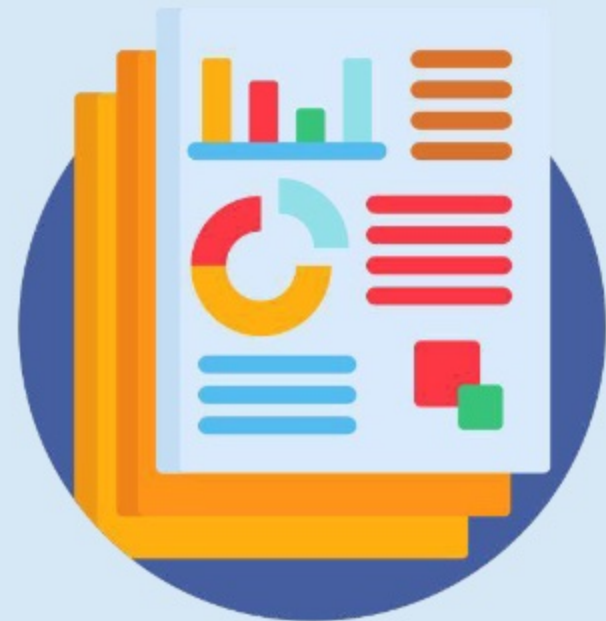


Scenario



SCENARIO

Users in an accounting management system build different types of reports using data from Salesforce. Currently, data is being exported from their org on a weekly basis using Data Loader and then uploaded into the accounting management system using a custom data import tool. The manual process occasionally results in misleading reports due to outdated data or its absence. The chief accounting officer would like to be able to view reports using recent data by ensuring the data is constantly and automatically updated.

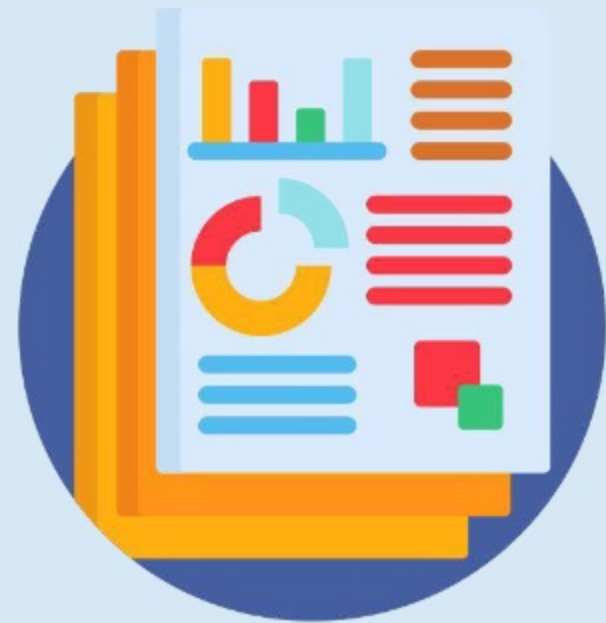


Solution



SOLUTION

In this scenario, a **connected app** can be created to allow the accounting management system to automatically access data from Salesforce. Using the **OAuth 2.0 Client Credentials flow**, the external system provides the **consumer key** and **consumer secret** in exchange for an access token. Once an access token is granted, a job can be run in the external system daily, for example, to import data from Salesforce that will be used in the reports.



Learn More

-  [Security Basics](#)
-  [Certificates and Keys](#)
-  [Get to Know Salesforce Identity](#)
-  [Learn the Language of Identity](#)
-  [Connected App and OAuth Terminology](#)
-  [Access Data with API Integration](#)
-  [Connected Apps](#)

Learn More

-  [OAuth Authorization Flows](#)
-  [SAML SSO Flows](#)
-  [Just-in-Time Provisioning for SAML](#)
-  [Understanding Authentication](#)
-  [Configure an Authentication Provider Using OpenID Connect](#)